



Elasticsearch Security and Health Assessment

Context-aware evaluation of Elasticsearch vulnerabilities, runtime consistency, configuration, health, and resilience. No exploit or state-changing operation was performed.

Generated 2026-08-28 07:57:03 UTC | scanner dev | profile standard | deep true

Cluster	docker-cluster
Elasticsearch	8.19.20
Target	http://127.0.0.1:19200/
Overall health	Critical score 10 / 100
Topology	1 nodes, 4 indices, 4 shards, 141.47 KiB data
Severity counts	critical 2, high 3, medium 3, low 0, info 0

Top risks

CRITICAL Elasticsearch HTTP traffic is not protected by TLS (http)

Network observers can read or modify Elasticsearch traffic; credentials sent over HTTP are exposed.

CRITICAL Credentials were sent over HTTP because plaintext authentication was explicitly allowed (http_plaintext_auth)

The operator override transmitted secrets on an unencrypted Elasticsearch HTTP connection.

HIGH No snapshot repository is configured (docker-cluster)

The cluster has no visible Elasticsearch snapshot backup path.

HIGH Disk-based shard allocation thresholds are disabled (cluster.routing.allocation.disk.threshold_enabled)

Elasticsearch can continue allocating shards to critically full nodes.

HIGH Cluster has unassigned shards (docker-cluster)

Primary shards can make data unavailable; replica shards reduce fault tolerance.

Top resource consumers

Node by disk

Resource	Usage
d8e662a14285	69.05%

Node by JVM heap

Resource	Usage
d8e662a14285	48.00%

Node by shards

Resource	Usage
d8e662a14285	4.00 shards

Index by storage

Resource	Usage
garga-sensitive-test	71.67 KiB

Detailed findings

1. ES-SEC-001 CRITICAL Elasticsearch HTTP traffic is not protected by TLS

Field	Value
Category	Security
Resource	transport/http
Confidence	HIGH
Threshold	HTTPS
Operational impact	Network observers can read or modify Elasticsearch traffic; credentials sent over HTTP are exposed.
Recommended action	Enable and verify TLS on the Elasticsearch HTTP interface or its trusted reverse proxy. Avoid sending credentials over HTTP.

Field	Value
Evidence	allow_plaintext_auth=true, credentials_used=[REDACTED], https_enabled=false

2. ES-SEC-001 CRITICAL**Credentials were sent over HTTP because plaintext authentication was explicitly allowed**

Field	Value
Category	Security
Resource	transport/http_plaintext_auth
Confidence	HIGH
Threshold	HTTPS or no credentials
Operational impact	The operator override transmitted secrets on an unencrypted Elasticsearch HTTP connection.
Recommended action	Use HTTPS and keep --allow-plaintext-auth disabled except for explicitly authorized, isolated tests.
Evidence	allow_plaintext_auth=true, credentials_used=[REDACTED], https_enabled=false

3. ES-BACKUP-001 HIGH**No snapshot repository is configured**

Field	Value
Category	Snapshot
Resource	cluster/docker-cluster
Confidence	HIGH
Threshold	at least one operational backup repository
Operational impact	The cluster has no visible Elasticsearch snapshot backup path.
Recommended action	Configure and monitor a snapshot repository through an authorized workflow. The health check does not verify or modify repositories.
Evidence	repositories=0

4. ES-CONFIG-001 HIGH**Disk-based shard allocation thresholds are disabled**

Field	Value
Category	Configuration
Resource	cluster_setting/cluster.routing.allocation.disk.threshold_enabled
Confidence	HIGH
Threshold	true
Operational impact	Elasticsearch can continue allocating shards to critically full nodes.
Recommended action	Re-enable disk thresholds through an authorized change after understanding why they were disabled.
Evidence	effective_value=false

5. ES-SHARD-001 HIGH

Cluster has unassigned shards

Field	Value
Category	Shard
Resource	cluster/docker-cluster
Confidence	HIGH
Threshold	0 unassigned shards
Operational impact	Primary shards can make data unavailable; replica shards reduce fault tolerance.
Recommended action	Use the allocation explanation and node/disk findings to resolve the allocation decider blocking these shards.
Evidence	allocation_reason=INDEX_CREATED, delayed_unassigned_shards=0, example_index=garga-sensitive-test, example_primary=false, example_shard=0, failed_allocation_count=0, last_allocation_status=no_attempt, reasons=map[INDEX_CREATED:1], unassigned_primaries=0, unassigned_shards=1

6. ES-AVAIL-001 MEDIUM

Single-node cluster has no node-level redundancy

Field	Value
Category	Availability
Resource	cluster/docker-cluster
Confidence	HIGH
Threshold	more than one node for node-level redundancy
Operational impact	A node or host failure makes the entire cluster unavailable.
Recommended action	For production workloads, deploy additional role-appropriate nodes across independent failure domains. A single node may be intentional in development.
Evidence	number_of_nodes=1, profile=standard

7. ES-CLUSTER-001 MEDIUM

Elasticsearch cluster health is YELLOW

Field	Value
Category	Cluster
Resource	cluster/docker-cluster
Confidence	HIGH
Threshold	GREEN
Operational impact	Unavailable primary shards can make data inaccessible; unavailable replicas reduce redundancy.
Recommended action	Resolve the underlying allocation or node failure before treating the cluster as healthy.
Evidence	active_primary_shards=4, active_shards=4, active_shards_percent=80, status=yellow, unassigned_shards=1

8. ES-INDEX-001 MEDIUM

Index health is YELLOW

Field	Value
Category	Index
Resource	index/garga-sensitive-test
Confidence	HIGH
Threshold	GREEN
Operational impact	Red indices can have unavailable data; yellow indices have reduced shard redundancy.
Recommended action	Resolve node, allocation, disk, and replica constraints associated with this index.
Evidence	health=yellow, primary_shards=1, replicas=1, status=open, store_bytes=73392

Prioritized action plan

P0 Immediate

- Enable and verify TLS on the Elasticsearch HTTP interface or its trusted reverse proxy. Avoid sending credentials over HTTP.
- Use HTTPS and keep --allow-plaintext-auth disabled except for explicitly authorized, isolated tests.

P1 Urgent

- Configure and monitor a snapshot repository through an authorized workflow. The health check does not verify or modify repositories.
- Re-enable disk thresholds through an authorized change after understanding why they were disabled.
- Use the allocation explanation and node/disk findings to resolve the allocation decider blocking these shards.

P2 Planned

- For production workloads, deploy additional role-appropriate nodes across independent failure domains. A single node may be intentional in development.
- Resolve the underlying allocation or node failure before treating the cluster as healthy.
- Resolve node, allocation, disk, and replica constraints associated with this index.

P3 Optimization

None.

Assessment coverage and scanner telemetry

Checks	35 executed / 39 available passed 28 skipped 4 failed 0 findings 8
API requests	17 retried 0 failed 1
Downloaded	90.07 KiB
Duration	811 ms

Collector	Cost	Status	HTTP	Reason
allocation_explain	MEDIUM	success	200	-
authenticate	LOW	success	200	-
cluster_health	LOW	success	200	-
cluster_settings	LOW	success	200	-
cluster_stats	LOW	success	200	-
data_streams	MEDIUM	success	200	-
ilm	HIGH	skipped	405	api_unavailable
index_settings	MEDIUM	success	200	-
indices	MEDIUM	success	200	-

Collector	Cost	Status	HTTP	Reason
nodes_info	LOW	success	200	-
nodes_settings	MEDIUM	success	200	-
nodes_stats	MEDIUM	success	200	-
pending_tasks	LOW	success	200	-
root	LOW	success	200	-
shards	MEDIUM	success	200	-
snapshot_repositories	MEDIUM	success	200	-
tasks	HIGH	success	200	-

Methodology

This assessment combines cluster health, node resources, JVM, disk, shard and index architecture, workload pressure, lifecycle, backup, security, capacity, availability, and reliability evidence. The Elasticsearch cluster-health color is not used as the sole health decision.

Developer Cuma Kurt | <https://www.linkedin.com/in/cuma-kurt-34414917/> | <https://github.com/cumakurt>